

day-28-approval-security-100-closure

Day 28 - Approval Security

Date: 2026-05-09

Branch: to-knowledge-mc

Status: CLOSED

Blocker class: NONE

Code commit: pending

Rollback: 'git revert <day28_commit_sha>'

Next day started: Day 29 - Approval Audit Export / Report

Closure Decision

Day 28 is closed.

Approval security now has focused regression coverage plus live route proof. Unauthenticated and invalid-key callers cannot approve, deny, or dispatch protected actions. Denial remains non-executing, replay-safe, and audited.

Implemented

Added focused route tests for:

- unauthorized denial attempts returning before persistence mutation
- owner denial creating a denial audit event
- owner denial creating zero connector run rows
- denial replay staying non-executing
- denial replay not adding a second audit row

Source file added:

- 'src/app/api/bridge/approval-requests/[id]/deny/route.test.ts'

No production route logic was changed; the existing implementation already enforced the required behavior.

Live Security Proof

Proof artifact:

'runtime/day-28-approval-security-proof.json'

Approval id:

'apr_3b58495a-cc51-47a7-9e17-75bd3801defc'

Protected routes checked:

- 'POST /api/bridge/approval-requests/{id}/approve'
- 'POST /api/bridge/approval-requests/{id}/deny'
- 'POST /api/bridge/brain-sync/build-wiki/run-now/{id}/dispatch'

Unauthenticated results:

- approve: 401
- deny: 401
- dispatch: 401

Invalid API key results:

- approve: 401
- deny: 401
- dispatch: 401

Owner cleanup denial:

- status: 200
- mode: 'approval_request_denied_no_execution'
- approval state: 'denied'
- accepted for execution: false
- execution enabled: false

Persistence proof:

- approval state: 'denied'
- run count: 0
- audit outcomes:
 - 'approval_requested'
 - 'denied'

Non-Owner Proof Note

A live non-owner credential was not available in this local runtime.

Blocker note:

'non_owner_runtime_credential_not_available'

This does not block Day 28 because the route-level regression test directly covers 'requireRole' rejection and verifies persistence is unchanged when authorization fails.

Verification

Fresh checks run after the test addition:

- 'git diff --check': pass
- 'pnpm run typecheck': pass
- 'pnpm run build': pass
- 'pnpm test': pass, 154 files / 1319 tests
- 'node scripts/check-protected-file-invariants.mjs': pass
- live approval security proof: pass
- staged secret scan: pending before commit
- '.env' diff check: clean

Safety Confirmation

- No '.env' changes.
- No secrets printed.
- No auth weakening.
- No public exposure added.
- No fake approval.
- No fake execution.
- No connector execution occurred during denied/security proof.
- No SMB.
- No Fork 2.
- No external farmers.
- No Zapier writes.
- No HeyGen generation.

Files Added

- 'src/app/api/bridge/approval-requests/[id]/deny/route.test.ts'
- 'runtime/day-28-approval-security-proof.json'
- 'runtime/day-28-approval-security-100-closure.md'
- 'runtime/day-28-approval-security-100-closure.pdf'

Remaining Blockers

None for approval security.

Day 29 Start

Day 29 - Approval Audit Export / Report begins next.

Goal:

Expose safe approval audit/report data with request, decision, result, and history without secrets, raw paths, or auth bypass.